

Report an die Datenschutzbeauftragte

scriptTelios — AI-Act-Einordnung, RunPod-Pilotbetrieb und erforderliche datenschutzrechtliche Entscheidungen · Stand 12.08.2026 · Erstellt: C. Wittenberg (Entwicklung)

1 · Anlass und Zusammenfassung

Seit dem 2. August 2026 gelten die wesentlichen Pflichten des EU AI Act; die Pflicht zur KI-Kompetenz (Art. 4) gilt bereits seit Februar 2025. Für scriptTelios — das intern entwickelte KI-Dokumentationswerkzeug der Klinik — wurde eine vollständige Standortbestimmung durchgeführt, die identifizierten Lücken wurden priorisiert und die formalen sowie technischen Maßnahmen weitgehend vorbereitet oder umgesetzt. Da die klinikeigene Hardware erst in einigen Monaten verfügbar ist, wurde entschieden, den Zehn-Nutzer-Pilot mit Echtdaten übergangsweise auf einem exklusiv gemieteten GPU-Server (RunPod Secure Cloud, Region EU-RO-1/Rumänien) zu betreiben. Dieser Report fasst den Stand zusammen und benennt die Punkte, die Ihre Prüfung, Bewertung bzw. Zeichnung erfordern, bevor Patientendaten verarbeitet werden.

2 · System in Kürze

scriptTelios erstellt aus Sitzungsaufnahmen, Transkripten und Quelldokumenten Entwürfe klinischer Dokumente (Gesprächsdokumentation, Anamnese/Befund, Kostenanträge, Verlängerungen, Entlassbericht, ISM-Fragebogen). Sämtliche KI-Inferenz läuft auf eigener Infrastruktur mit lokalen Modellen; es werden keine externen KI-Dienste genutzt und keine Modelle mit Patientendaten trainiert. Jeder Output ist ein Entwurf, den die behandelnde Therapeut:in prüft, bearbeitet und verantwortet. Die Klinik ist im Sinne des AI Act zugleich Anbieter (Eigenentwicklung unter eigenem Namen) und Betreiber.

3 · AI-Act-Einordnung (zur Bestätigung)

Nach der vorliegenden Klassifizierung (Anlage A1) ist scriptTelios kein Hochrisiko-KI-System: keine Anhang-III-Kategorie einschlägig, kein Medizinprodukt i.S.d. MDR (reine Dokumentationsunterstützung, MDCG 2019-11), durchgängige menschliche Letztverantwortung. Einschlägig sind damit Art. 4 (KI-Kompetenz — Schulungspaket liegt vor, Anlage C), Art. 50 Abs. 1 (Transparenz — permanenter UI-Hinweis ist implementiert) sowie die Basis-Dokumentationspflichten. Eine Kennzeichnung jedes generierten Dokuments ist nicht erforderlich, da Krankenakte und Anträge an Kostenträger keine Veröffentlichung zur Information der Öffentlichkeit darstellen und stets menschliche Prüfung erfolgt. **Ihre Aufgabe: Bestätigung der Klassifizierung (Freigabeblock in Anlage A1).**

4 · DSGVO-Stand

Bereich	Stand
Datenschutzaudit v2 (04/2026)	9 von 13 Empfehlungen im Code umgesetzt (Auth, CORS, Audit-Logging, Löschkonzept, Rate-Limiting, Datenminimierung). Offen als Infrastrukturaufgaben: TLS-Zertifikat (K2), Disk-Encryption (E3), Off-Site-Backup (E5) — werden mit dem On-Prem-Aufbau geschlossen.
Retention (neu, 08/2026)	Automatische 90-Tage-Löschung technisch umgesetzt und getestet: Jobs (inkl. Transkripte/Entwürfe), Recording-Zeilen inkl. DB-Transkript, feedback.log (vorher 10 Jahre); prompts.log rotiert mit 14 Tagen. Audio wird weiterhin nach 24 h gelöscht.
Einwilligung	v1.1 formuliert (Anlage A3): §1 präzisiert (dedizierte, ausschließlich klinik-kontrollierte EU-Server), §1a Transparenz zur Übergangsinfrastruktur, §6a Qualitätssicherungs-Auswertung max. 90 Tage. Die optionale Forschungsklausel (§7 aus v1.0) ist vorerst gestrichen und kommt erst in der Produktivphase (v1.2) zurück.

5 · Übergangsbetrieb RunPod (Beschluss H2)

Der Pilot läuft auf einem dedizierten Pod in der RunPod Secure Cloud, Region EU-RO-1 (T3/T4-Rechenzentrum; RunPod: SOC 2 Type II, seit 02/2026 auditierte GDPR/HIPAA-Konformität). Zentraler Befund der Vertragsprüfung: RunPods Standard-DPA (inkl. EU-Standardvertragsklauseln 2021/914, Modul 2) wird erst durch unterschriebene Einreichung wirksam — **derzeit besteht kein AVV**; bis zu dessen Abschluss werden ausschließlich synthetische Testdaten verarbeitet. Das DPA verlangt zudem eine schriftliche Vorab-Notifikation über die Verarbeitung besonderer Kategorien (Art. 9). Beides ist vorbereitet (Anlage A4/B1). Die On-Prem-Migration bleibt geplant; mit ihr entfallen §1a der Einwilligung, TIA und DPA.

6 · Ihre Entscheidungs- und Prüfpunkte

#	Punkt	Anlage	Aufwand
E1	AI-Act-Klassifizierung prüfen und zeichnen	A1	~0,5 PT
E2	RunPod-DPA prüfen; Ausfertigung über Signaturblatt begleiten (Unterschrift Klinikleitung); Special-Categories-Notifikation freigeben	A4, B1	~0,5 PT
E3	Transfer Impact Assessment finalisieren und zeichnen — offene Felder: FISA-702-/CLOUD-Act-Würdigung, Prüfung einer DPF-Zertifizierung RunPods, Bestätigung der 90-Tage-Frist	A2	0,5–1 PT
E4	§ 203 StGB-Votum: Tragfähigkeit der Einbindung RunPods ohne deutsche Verpflichtungserklärung (kein inhaltlicher Zugriff laut DPA/ToS). Kritischster Punkt — ohne positives Votum kein Echtdaten-Start	A2 §2	0,5–1 PT (ggf. externe jur. Beratung)
E5	Einwilligung v1.1 finalisieren: Kopplungsverbots-Würdigung zu §6a (Verortung als Pflichtbestandteil; Fallback als separates Ankreuzfeld liegt formuliert vor), Kontaktdaten einsetzen, Druckfreigabe	A3	~0,5 PT
E6	Formelle DSFA (Art. 35) auf Basis Audit v2, Klassifizierung und TIA — durch den Cloud-Übergang nicht weiter aufschiebbar	A1, A2, Audit v2	2–3 PT (Zuarbeit Entwicklung zugesagt)
E7	Verarbeitungsverzeichnis (Art. 30) um scriptTelios/RunPod inkl. Drittlandmechanismus ergänzen	—	~0,5 PT

Vor dem ersten Echtdaten-Job wird die Go-Live-Checkliste (Anlage A4, Schritt 8) gemeinsam abgehakt: DPA-Bestätigung, Notifikation, Pod-Nachweis Secure Cloud EU-RO-1 (liegt vor), TIA, § 203-Votum, DSFA, unterschriebene v1.1 je Pilot-Patient:in, dokumentierte Schulung aller zehn Nutzer:innen, aktualisiertes Verarbeitungsverzeichnis.

7 · Technische Schutzmaßnahmen (Kurzfassung für die DSFA)

TLS in Transit (Cloudflare-Tunnel), HMAC-Authentifizierung mit Replay-Schutz, Therapeut-Zuordnung aus validiertem Header, Rate-Limiting, Audit-Log ohne Inhalte (90 Tage), Log-Datenminimierung, Quellen-Gate gegen konfabulierte Inhalte, Initialen statt Klarnamen in Outputs, 24-h-Audio-Löschung, 90-Tage-Löschung aller Verarbeitungsdaten (§6a), kein Modelltraining mit Patientendaten, keine externen KI-Dienste. Offen und in Klärung: At-Rest-Verschlüsselung der Region EU-RO-1 (Ergebnis fließt in TIA §5; falls plattformseitig nicht vorhanden, ist eine applikationsseitige Härtung vorbereitet).

8 · Anlagenverzeichnis (Gesamtpaket vom 12.08.2026)

Nr.	Dokument
A1	g1_ai_act_klassifizierung_scriptTelios.md — Risikoklassifizierung mit Freigabeblock
A2	h2_tia_entwurf_runpod.md — TIA-Entwurf, vorbefüllt, Region EU-RO-1 eingetragen

Nr.	Dokument
A3	g3a_einwilligung_v1_1_formulierung.md — Änderungsfassung Einwilligung v1.1 (§1, §1a, §6a; §7 zurückgestellt)
A4	h2_umsetzungsplan_runpod_echtdaten.md — 8-Schritte-Plan inkl. Notifikationsentwurf und Go-Live-Gate
B1	runpod_dpa_signaturblatt.pdf — Ausfertigungs-/Signaturblatt zum RunPod-DPA
B2	f1_runpod_avv_recherche.md — Vertrags-/Compliance-Recherche RunPod
C	g2_schulung_pilotnutzer_scriptTelios.md + g2_uebungsfall_teil_e.md — Schulungspaket Art. 4
D	ai_act_gap_analyse_scriptTelios.md — vollständige Gap-Analyse
E	Technik: Patches g6_ki_transparenzhinweis_v2 und retention_90d_par6a inkl. Testnachweisen (INDEX.md im Paket)

Rückfragen und Zuarbeit: C. Wittenberg, c.wittenberg@systelios.de. Alle genannten Anlagen liegen im Gesamtpaket scriptTelios_ai_act_gesamtpaket_2026-08-12.zip bei.

Zur Kenntnis genommen (Datenschutzbeauftragte:r)

Datum, Unterschrift